

Security+ 1.2 · Non-repudiation

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2 — Non-repudiation (7:57)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Non-repudiation: irrefutable proof of WHO did it — impossible to deny afterward. Implementation: hash of the data encrypted with the PRIVATE key of the signer (digital signature). Anyone validates with the public key. Basis for digital contracts, transactions, audit logs.

High-Yield Core Concepts Tested on Exam

- Hash only proves integrity; signature proves integrity + AUTHOR
- Asymmetric: private signs, public validates
- Non-repudiation proof: 'it wasn't me' is impossible to claim after signing

Exam Tips & Classic Scenarios

- If the question mentions 'cannot deny'/'cannot dispute' = non-repudiation
- Which algorithm: RSA signature (not AES — AES is symmetric, no single author)

Typical Exam Scenario: Typical scenario: 'company needs to prove to the court that the manager sent the order' → digital signature (non-repudiation) with the manager's private key.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — Non-repudiation)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **MAC:** Mandatory Access Control: Rigid label-based access architecture (Top Secret, Secret, Unclassified) enforced centrally by security kernel according to formal classification policies.
- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A senior executive claims in court that he never authorized the transfer of 5 million dollars via email, stating that the message was forged by third parties. The forensic team demonstrates that the email was signed with the executive's private key linked to his smart card. Which security property refutes the executive's claim?

- A)** Symmetric confidentiality
- B)** Non-repudiation
- C)** Availability with failover
- D)** Isolated SHA-256 hashing

2. A software company needs to distribute firmware updates and ensure that devices accept only legitimate packages and that the company cannot claim that someone else sent the firmware. What should be implemented?

- A)** Digital signature of the binary using the company's private key
- B)** AES-256 encryption of the binary with a shared key
- C)** MD5 hash calculation made available on the website
- D)** Code obfuscation with ZIP compression

3. Why is a pure SHA-256 hash (without a key or signature) NOT sufficient to guarantee non-repudiation of a document?

- A)** Because the hash is reversible and can be decrypted
- B)** Because anyone can recalculate the hash of a tampered document
- C)** Because the hash only protects data in motion, not at rest
- D)** Because the hash requires two keys to be validated

4. In a digital signature scheme for non-repudiation, which key is used to SIGN the cryptographic digest and which is used by the recipient to VALIDATE the signature?

- A)** Sign with the sender's public key; validate with the sender's private key
- B)** Sign with the recipient's private key; validate with the recipient's public key
- C)** Sign with the sender's private key; validate with the sender's public key
- D)** Sign with a shared symmetric AES key; validate with the same key

5. A financial organization needs to record logs of banking transactions in regulatory compliance. To ensure that not even database administrators can alter or deny past entries, which combined technique should be used?

- A)** WORM (Write Once, Read Many) storage digitally signed with timestamping
- B)** Reversible encryption with key stored in plaintext
- C)** Weekly compressed backups without encryption
- D)** Discretionary read permissions for all users

6. A security analyst investigates a non-repudiation failure where an employee claims that another employee used their computer to sign a contract. Which complementary control reinforces user non-repudiation?

- A)** Automatic screen lock and biometric/MFA authentication to release the private key
- B)** Increasing hard drive size
- C)** Replacing the Ethernet cable with protected Wi-Fi
- D)** Disabling operating system logs

7. Which element of Public Key Infrastructure (PKI) formally and legally binds a person's identity to their public key to support non-repudiation?

- A)** Digital Certificate signed by a Certificate Authority (CA)
- B)** Edge firewall routing table
- C)** MD5 hash of the network card (MAC address)
- D)** Dynamic DNS server (DDNS)

8. A digital contract between two companies was electronically signed. Five years later, one party attempts to invalidate the contract claiming that the hash algorithm used at the time was weak. Which mechanism protects the long-term legal validity against this challenge?

- A)** Trusted cryptographic timestamp (Time Stamping Authority - TSA) applied at the time of signing
- B)** Printed copy of the system source code
- C)** Replacing the public key with a secret symmetric key
- D)** Periodic restart of web servers

9. If Bob sends an encrypted message using only Alice's PUBLIC key, which security pillar was met and which was NOT?

- A)** Confidentiality was met; sender non-repudiation was NOT met
- B)** Non-repudiation was met; Confidentiality was NOT met
- C)** Both were perfectly met
- D)** No objective was achieved

10. For Bob to send a message to Alice while ensuring both CONFIDENTIALITY and NON-REPUDIATION of the sender, what is the correct flow of asymmetric keys?

- A)** Bob signs the message with his own private key and encrypts the result with Alice's public key
- B)** Bob encrypts with Alice's private key and signs with Bob's public key
- C)** Bob uses the same public key for both encrypting and signing
- D)** Alice signs beforehand and sends the key for Bob to encrypt

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Non-repudiation.

✓ **Why it's correct:** Non-repudiation irrefutably guarantees the identity of the author of a transaction through digital signature (asymmetric private key), preventing them from later denying the sending. The use of the executive's private key, protected by a smart card, provides strong proof of origin and integrity, making it impossible for the executive to deny having signed the message.

✗ **Why the others are wrong:**

- *Symmetric confidentiality:* Symmetric encryption ensures confidentiality but does not provide proof of origin or non-repudiation, as both parties share the same key. It cannot refute the executive's claim because anyone with the key could have created the message.
- *Availability with failover:* Availability ensures that systems and data are accessible when needed, but it does not address proof of authorship or integrity of a specific transaction. It is irrelevant to refuting the executive's denial.
- *Isolated SHA-256 hashing:* Hashing provides integrity verification but, when used alone, does not authenticate the sender or provide non-repudiation. An attacker could alter the message and recompute the hash. Only when combined with a digital signature does it contribute to non-repudiation.

2) A — Digital signature of the binary using the company's private key.

✓ **Why it's correct:** Digital signatures provide origin authentication, integrity, and non-repudiation, because only the holder of the developer's private key can sign the package.

✗ **Why the others are wrong:**

- *AES-256 encryption of the binary with a shared key:* Provides confidentiality but not origin authentication or non-repudiation; a shared key means anyone with the key could have created the package.
- *MD5 hash calculation made available on the website:* MD5 is cryptographically broken (collision-prone) and a hash alone does not prove who created the package; it only verifies integrity if the hash is trusted.
- *Code obfuscation with ZIP compression:* Obfuscation and compression are not security controls for authenticity or integrity; they can be reversed and do not prevent tampering.

3) B — Because anyone can recalculate the hash of a tampered document.

✓ **Why it is correct:** A hash function provides only mathematical integrity (whether the data has changed). It has no identity binding: anyone can alter the text and generate a new corresponding hash. Without a digital signature or HMAC, there is no cryptographic proof of who created or approved the document, so non-repudiation cannot be guaranteed.

✗ **Why the others are wrong:**

- *Because the hash is reversible and can be decrypted:* Hash functions are one-way and not reversible; they are not encryption algorithms.
- *Because the hash only protects data in motion, not at rest:* Hashing can be applied to data at rest or in motion; the limitation is not about state but about lack of identity binding.
- *Because the hash requires two keys to be validated:* Hashing does not use keys; it is a keyless integrity mechanism. Two-key systems refer to asymmetric encryption or HMAC, which are different constructs.

4) C — Sign with the sender's private key; validate with the sender's public key.

✓ **Why it is correct:** A digital signature is generated by encrypting the document hash with the sender's PRIVATE key (only they possess it). The recipient validates the signature using the sender's PUBLIC key. This ensures authenticity, integrity, and non-repudiation.

✗ **Why the others are wrong:**

- *Sign with the sender's public key; validate with the sender's private key:* This reverses the key roles. The public key is freely distributed and cannot be used to create a signature that only the sender could produce; anyone could sign with the public key, destroying non-repudiation.
- *Sign with the recipient's private key; validate with the recipient's public key:* This would mean the recipient signs the message, not the sender. It provides no proof of the sender's identity and is not how digital signatures work.
- *Sign with a shared symmetric AES key; validate with the same key:* Symmetric keys are shared secrets and do not provide non-repudiation because both parties possess the same key. Anyone with the key could have created the signature, so it cannot prove the sender's identity.

5) A — WORM (Write Once, Read Many) storage digitally signed with timestamping.

WORM media prevent later modifications, and digitally signed timestamping proves when the event occurred and who generated it, ensuring integrity and non-repudiation.

✗ **Why the others are wrong:**

- *Reversible encryption with key stored in plaintext:* This does not prevent administrators from altering or deleting logs; it only obscures data. If the key is stored in plaintext, anyone with access can decrypt and modify entries, violating integrity and non-repudiation.
- *Weekly compressed backups without encryption:* Backups are not immutable and can be altered or deleted by administrators. Without encryption, they are also vulnerable to unauthorized access. This does not meet regulatory requirements for tamper-evident logging.
- *Discretionary read permissions for all users:* This grants broad access, increasing the risk of tampering and unauthorized disclosure. It does not prevent administrators from modifying logs and fails to provide non-repudiation.

6) A — Automatic screen lock and biometric/MFA authentication to release the private key.

✓ **Why it is correct:** For non-repudiation to be indisputable in forensic practice, the private key must be protected by rigorous authentication factors (smart card + PIN/biometrics) and physical locking. This ensures that only the legitimate user can access the private key, binding the digital signature to their identity and preventing claims of unauthorized use.

✗ **Why the others are wrong:**

- *Increasing hard drive size:* Does not address authentication or key protection; storage capacity is irrelevant to non-repudiation.
- *Replacing the Ethernet cable with protected Wi-Fi:* While network security is important, it does not prevent a user from denying having signed a contract; it only protects data in transit.
- *Disabling operating system logs:* Eliminates audit trails and forensic evidence, further weakening non-repudiation and accountability.

7) A — Digital Certificate signed by a Certificate Authority (CA).

The Digital Certificate (X.509) issued by a trusted CA publicly attests to the binding between the public key and the entity/individual holder. This binding, backed by the CA's digital signature, provides the cryptographic proof needed for non-repudiation: the holder cannot later deny having signed data with the corresponding private key. The other options are unrelated to identity binding: a firewall routing table controls packet forwarding, an MD5 hash of a MAC address is not

a certificate and MD5 is cryptographically broken, and DDNS maps domain names to dynamic IP addresses.

8) A — Trusted cryptographic timestamp (Time Stamping Authority - TSA) applied at the time of signing.

A timestamp issued by a trusted authority (TSA) proves that the signature was created before the expiration or obsolescence of the certificate and algorithms. This provides long-term validation and non-repudiation, ensuring the signature's legal validity even if the hash algorithm is later compromised.

✗ Why the others are wrong:

- *Printed copy of the system source code:* Does not provide any cryptographic proof of when the signature was created and is irrelevant to the validity of the digital signature.
- *Replacing the public key with a secret symmetric key:* This would not help; symmetric keys are not used for digital signatures and do not provide timestamping or long-term validation.
- *Periodic restart of web servers:* Has no impact on the cryptographic validity of a digital signature or the timestamping of the contract.

9) A — Confidentiality was met; sender non-repudiation was NOT met.

Encrypting with Alice's public key ensures that only Alice can read it (Confidentiality). However, since Alice's public key is publicly available, anyone could have sent the message; therefore, there is no sender non-repudiation.

10) A — Bob signs the message with his own private key and encrypts the result with Alice's public key.

Signing with Bob's private key provides non-repudiation/authenticity. Encrypting with Alice's public key ensures confidentiality exclusive to Alice.

✗ Why the others are wrong:

- *Bob encrypts with Alice's private key and signs with Bob's public key:* Alice's private key should never be shared or used by Bob; encryption with a private key does not provide confidentiality (anyone with the corresponding public key can decrypt). Signing with a public key is invalid; signatures require the sender's private key.
- *Bob uses the same public key for both encrypting and signing:* Public keys are for encryption or verification, not for signing. Signing requires a private key. Using the same key for both purposes is cryptographically insecure and does not achieve the required security properties.
- *Alice signs beforehand and sends the key for Bob to encrypt:* This reverses roles and does not provide non-repudiation for Bob as the sender. Alice signing does not prove Bob sent the message. Sending a key compromises security and does not follow asymmetric encryption principles.